

A2A Threat Model — Facilitator Guide

Day 1 · after Module 3 · 25 min total · each pod works its OWN case

How to run it

- **0–4 min:** hand out the participant sheet; walk the five steps and the whiteboard notation once.
- **4–18 min:** pods draw their own case. Circulate hard — this is the exercise where pods drift, because it's their own system. Keep them moving to the **highest-privilege action** fast; everything hangs off it.
- **18–25 min:** each pod states, in 30 seconds: its ★ action, its worst path, and its one control. Then hand out the gold (SettleNet) sheet.
- **Materials:** participant sheet per pod, whiteboard/markers, gold sheet held back.

Questions to ask while circulating

GENERAL

- “Point to the one action you can't undo. Start there and work backwards.”
- “Draw the dashed line. What's outside it? Is the vendor / user / fetched data inside or outside?”
- “Does your attack need a hacker, or just untrusted data reaching a privileged agent?”
- “If two agents share one set of credentials, is your privilege separation real?”

TARGETED NUDGES

- **SettleNet (04):** “Is the vendor agent inside or outside your boundary? What does it hand the posting agent?”
- **Navigator (03):** “The customer types into the agent. Where does that text end up?”
- **Second Line (05):** “Your reviewer agent reads documents written by the team being reviewed. And?”

Misconceptions to watch for

- **Trust boundary drawn too generously** — pods put the vendor or the user inside it. The boundary is what *you* control, full stop.
- **“Privilege” confused with “importance.”** The orchestrator feels central, but the posting agent is the one that moves money.
- **Assuming an attack needs a break-in.** Poisoned data and a confused deputy need no credentials at all.
- **Forgetting non-human identity.** Shared credentials collapse every privilege boundary they drew.

Debrief — land this

Across six very different cases, the same shape appears: an irreversible action, a trust boundary, and a short path of untrusted data to that action. **Punchline:** A2A risk isn't exotic hacking — it's *plumbing and identity*. The control that breaks the path is almost always the same family they met in the harness teardown: scope the privilege, separate the identities, and put a human before the irreversible step. This is exactly the surface the Day-2 adversarial studio attacks.

How it connects

Direct continuation of the harness teardown (line 10 checkpoints, line 11 untrusted output). The worst-path thinking is what the Day-2 red-team relay weaponizes, and SettleNet's and Navigator's curveballs both live on this surface.

Illustrative for the exercise only. A real threat model is broader and bank-specific. This is a 25-minute scaffold, not a complete security assessment.